

Infrastructure Hardening Standards



Configuration and Hardening Standards

Servers and Virtual Machines

This is the standard for system-level server and virtual server (VM) configuration hardening. Some customization to these settings may be required to configure the system for its specific target environment, such as setting the proper names, groups, authentication settings, and other personalization options.

The OS baseline for our services will be the latest AWS managed machines.

In addition to the requirements to secure systems to the baseline outlined above, all physical and virtual systems must adhere to the following technical requirements:

- All vendor defaults (including default passwords on operating systems, software providing security services, application and system accounts, Simple Network Management Protocol (SNMP) community strings, etc.) must be changed before a system is installed on the network.
- Unnecessary default accounts (including accounts used by operating systems, security software, applications, systems, SNMP, etc.) must be removed or disabled before a system is installed on the network.
- Only one primary function may be implemented per server or virtual machine to prevent functions that require different security levels from coexisting on the same system.
- Only necessary services, protocols, daemons, etc., may be enabled, and only as required for the function of the system. All unnecessary functionality (such as scripts, drivers, features, subsystems, file systems, and unnecessary web servers) must be disabled.
- Additional security features for any required services, protocols or daemons that are considered to be insecure must be documented in Appendix B of this document, justified, and tested to ensure that they do not introduce unnecessary risk or vulnerabilities.
- All security patches identified as critical, high, or medium must be applied to systems within SLAs established in this policy.

Network Standards

- Management of network rules and settings may only be performed by authorized members of the DevOps team and all changes must comply with change Management procedures defined in the Operations Security Policy.
- Network diagrams must be created and kept current. Significant changes (additions or deletions to VPCs and subnets, new external connections, etc.) must be documented in the diagrams; even if no changes occurred, the diagrams will be reviewed at least annually for completeness and accuracy, and approved/acknowledged (in version number/date field etc.) by authorized members of the DevOps and Software Engineering teams.
- Supported network controls for production networks are AWS Security Group ACLs. Management of production network systems is accomplished through the use of the AWS Console.
- In the Production Environment, defined rules and configurations must be enforced to control traffic from untrusted networks (e.g. publicly available services) to internal production networks; additionally, rules must be in place to restrict traffic to and from production networks to untrusted networks, and all inbound and outbound traffic must be evaluated by the the traffic management configuration.
- Network control systems must be configured to use default Network Address Translation to prevent the disclosure of internal IP addresses to the Internet. If private IP addresses are used, any disclosure to external parties must be appropriately authorized, documented, and periodically reviewed for business necessity.
- Mobile devices connecting to production networks must employ the use of a personal firewall or equivalent (such as endpoint protection with network restrictions enabled). Disabling or bypassing personal firewalls while connected to Sensor Global Pty Ltd systems is prohibited. Personal firewalls must be configured to specific standards, including: disabling the use of split tunneling, configurations to block known malicious sites, blocking of insecure protocols.
- All network control systems must be configured with default antispoofing rules to block or deny inbound internal addresses originating from the Internet
- Network control systems may only allow established connections into the internal network and must deny any inbound connections not associated with a previously established session.
- External configurations must limit inbound traffic to only system components that provide authorized publicly accessible services, protocols, and ports.
- Port and IP ranges are prohibited unless specifically reviewed and justified; all available services must be justified, and support secure configurations, all other ports, services, and network traffic must be specifically denied.

- Use of insecure services and protocols without justification and documentation of additional security features implemented to mitigate risk is prohibited.
- Remote access sessions must be configured to enforce timeout after a specified period of (X hours).
- Remote-access technologies for vendors and business partners used to access production systems must be enabled only when needed for business purposes and immediately deactivated after use.
- Any hybrid networks with both cloud and on-premise access shall be scanned and tested at least annually to ensure that security requirements are maintained

Specific NACLs, ports, zones, and services allowed in and out of the production environment are defined below: Rules and allowed traffic must be evaluated at least annually and formally approved by the Software Development Manager:

Source Zone	Dest. Zone	Source Address	Dest. Address	Service	Action	Purpose
Trust	Dev	43.250.158.239/32	Odoo Security Groups	SSH	Permit	Hardik Patel Home
Trust	Dev	144.136.29.76/32	Odoo Security Groups	SSH	Permit	Sensor Head Office
Trust	Dev	139.99.134.156/32	Odoo Security Groups	SSH		Syahrial Port Cities
Trust	Dev	202.168.29.41/32	Odoo Security Groups	SSH		Sam Collins
Trust	Dev	139.99.170.149/32	Odoo Security Groups	SSH		Syahrial Port Cities Monitoring
Trust	Dev	58.161.9.24/32	Odoo Security Groups	SSH		Mat Loftus Home

Untrust	EXT	All	Web Services and Load Balancers	HTTP HTTPS	Permit	Allow inbound web services from the Internet
Untrust	Trust	All	All	Any	Deny	Default deny all